

Informe Ejecutivo de Gestión de Riesgos Informáticos

Dirigido a: Directorio General — Clínica Privada de la Ciudad de Mendoza
Elaborado por: Consultor de Seguridad — Marco Asensio
Fecha: Septiembre de 2026
Estado de la plataforma: Validado e Implementado en Entorno Corporativo (SimpleRisk Core)

1. Resumen Ejecutivo

Tras la reciente auditoría externa que identificó debilidades en la gestión de activos y salvaguardas de la institución, se procedió a realizar un relevamiento técnico profundo de la infraestructura informática. La clínica cuenta con una operación crítica que abarca **120 empleados**, una afluencia de **800 pacientes diarios** y el manejo masivo de Historias Clínicas Digitales (HCD), datos financieros y facturación de obras sociales.

La falta de controles automatizados expone a la organización a vectores de ataque de alto impacto. Con el objetivo de mitigar estas brechas, se ha desplegado con éxito una plataforma centralizada de gobernanza (SimpleRisk) mediante contenedores reproducibles (Docker). Se determinó que los activos más críticos (servidores de bases de datos y canales de comunicación) carecen de redundancia y protección perimetral avanzada, elevando la superficie de exposición a incidentes de Ransomware y fugas de información.

2. Top 5 Riesgos por Nivel Resultante

Evaluados mediante la metodología estandarizada de SimpleRisk en escala de 1 a 5 (Probabilidad x Impacto):

1. ID 1002 — Ataque de Ransomware y Encriptación de Servidores Críticos		NIVEL CRÍTICO · SCORE 20	
Probabilidad	4 (Probable)	Impacto	5 (Catastrófico)
Activos	Servidores de Aplicaciones y Base de Datos Central.		
Justificación	Infiltración externa por malware que paralizaría el 100% de la clínica, forzando el cese operativo inmediato.		

2. ID 1003 — Exfiltración de Historias Clínicas por Acceso No Autorizado		NIVEL CRÍTICO · SCORE 15	
Probabilidad	3 (Posible)	Impacto	5 (Catastrófico)
Activos	Base de Datos de Pacientes (HCD).		
Justificación	Robo de datos médicos sensibles que derivaría en sanciones legales severas (Ley de Protección de Datos Personales) y daño reputacional letal.		

3. ID 1005 — Pérdida de Datos Médicos por Ausencia de Backups Inmutables**NIVEL CRÍTICO · SCORE 15**

Probabilidad	3 (Posible)	Impacto	5 (Catastrófico)
Activos	Servidor de Almacenamiento Principal.		
Justificación	Inexistencia de respaldos offline; ante un fallo lógico, la pérdida de antecedentes médicos históricos sería irreversible.		

4. ID 1001 — Indisponibilidad Operativa por Falla de Energía en Data Center**NIVEL ALTO · SCORE 12**

Probabilidad	3 (Posible)	Impacto	4 (Mayor)
Activos	Servidor de Historias Clínicas (Guardia).		
Justificación	Interrupción de la consulta médica en la guardia para los 800 pacientes diarios debido a cortes estacionales en la red eléctrica comercial.		

5. ID 1004 — Fuga de Información Confidencial por Ingeniería Social**NIVEL ALTO · SCORE 12**

Probabilidad	4 (Probable)	Impacto	3 (Moderado)
Activos	Datos de Obras Sociales y Facturación.		
Justificación	El personal administrativo comparte credenciales o envía planillas de facturación por canales inseguros (como WhatsApp personal) debido a alta rotación y falta de capacitación.		

3. Estado de los Planes de Acción

Se han diseñado e integrado en la plataforma tres (3) planes de mitigación urgentes dirigidos a los riesgos de nivel Crítico y Alto:

Plan	Riesgo	Descripción	Responsable	Presupuesto	Vencimiento	Estado
Plan 1	ID 1002	Estrategia de Backups 3-2-1 e Inmutabilidad con Firewall NGFW.	Director de TI (dir_ti)	USD 4.500	31/12/2026	En Planificación
Plan 2	ID 1003	Cifrado de Base de Datos y Despliegue de Autenticación Multifactor (MFA).	Oficial de Seguridad (analista_seg)	USD 2.800	30/11/2026	En Planificación
Plan 3	ID 1004	Programa de Concientización en Phishing y Bloqueo de Canales Inseguros (GPO).	Oficial de Seguridad (analista_seg)	USD 1.200	15/10/2026	En Planificación

Presupuesto total requerido: USD 8.500 — Todos los planes se encuentran actualmente en estado *En Planificación (Planning)* dentro de la plataforma SimpleRisk.

4. Recomendaciones Prioritarias para el Directorio

Para mitigar las vulnerabilidades críticas detectadas por la auditoría externa en el menor plazo posible, se recomienda:

1	Aprobación Presupuestaria Inmediata (USD 8.500 totales) Financiar de forma prioritaria los 3 planes de acción cargados en SimpleRisk para neutralizar los vectores de Ransomware y Exfiltración.
2	Implementación de MFA Obligatorio Restringir todo acceso a las Historias Clínicas Digitales únicamente mediante doble factor de autenticación para los 120 empleados.
3	Auditoría de Respaldo Semanal Encomendar al rol de auditor (auditor_salud) la fiscalización de las pruebas de restauración de backups para asegurar la continuidad del negocio ante contingencias operativas.

Documento generado a partir del relevamiento técnico validado en la plataforma SimpleRisk Core. Confidencial — distribución exclusiva para el Directorio General.